Build a complete workspace architecture plan for admin, investors, board, and alumni — permission matrix, data silos, and security models

Computer
Interactive stakeholder portal prototype: design custom workspaces for administrators, investors, board members, and alumni with live access controls
Computer
Draft the Investor and Board workspace workflows
Map out the Company and Admin workspace permissions
Design the cross-workspace education graph schema
Sources
7

Built a downloadable interactive stakeholder portal prototype and a machine-readable demo permission catalog. The architecture below defines Company, Admin, Investor, Board, and Alumni workspaces, their permission boundaries, data partitions, workflows, and cross-workspace education graph.

The prototype provides role switching, scope changes, simulated MFA, revocation, allow/deny decisions, reporting approvals, integration-change approvals, and a local decision trail. It uses synthetic data only.

The critical distinction is **authorization**: the prototype demonstrates policy behavior in the browser; it does not provide production security, authenticated identities, or live access to connected systems. I have not modified GitHub, Supabase, Vercel, or any institutional environment.

1. Architecture and implementation status

Evidence boundary

The inspected institutional templates already provide a useful visual foundation: role-aware navigation, environment and scope indicators, provenance-labelled metrics, action previews, and decision trails. Their example approval handlers change local component state, so those interactions are prototype evidence—not proof of server-side authorization or official-record writes. [1] [2]

The uploaded architecture snapshot, dated October 4, reports incomplete policy-spine adoption, database-function ownership risks, and missing enforcement of tenant AI policy at model invocation. These are dated reported blockers to verify against the active system before production activation. [3]

Proposed system structure

```
Shared Semester application shell
├── Company workspace
├── Institution/Admin workspace
├── Investor workspace
├── Board workspace
└── Alumni workspace
          |
Authenticated request boundary
          |
Context resolver
identity → organization → membership → resource scope
          |
Policy decision
capability + relationship + classification + purpose
+ consent, where applicable + session assurance + workflow state
          |
Domain services
company | administration | reporting | governance | alumni
          |
Canonical records + restricted projections
          |
Audit + outbox + reconciliation + evidence
```

Search, files, notifications, background workers, graph traversal, and AI retrieval must use the same authorization context. They must not become alternate routes around domain permissions.

Workspace responsibilities

Workspace	Primary responsibility	Explicit exclusion
Company	Product delivery, commercial operations, finance, implementation, trust	No default access to institution-owned educational records
Admin	Institution-scoped provisioning, configuration, integration, migration, recovery	No automatic academic decision authority
Investor	Approved company disclosures, diligence, questions, assistance	No live operational browsing or governance authority
Board	Oversight, meeting materials, decisions, committees, follow-up	No implicit platform administration
Alumni	Personal evidence, mentoring, network, careers, lifelong learning	No continuation of expired student privileges

Separate Semester corporate governance from institutional governance. An institution's trustee, a Semester director, and an investor are different relationships.

2. Permission model

Authorization rule

A proposed production policy should evaluate:

```
ALLOW only when:
  authenticated identity is active
  AND membership is active
  AND selected context belongs to that membership
  AND capability covers the requested action
  AND resource scope is permitted
  AND relationship constraints are satisfied
  AND classification permits the requested purpose
  AND required consent or institutional authority exists
  AND session assurance is sufficient
  AND workflow prerequisites hold
  AND no applicable explicit deny exists
```

Default to deny. Missing policy context, failed policy evaluation, and unavailable authorization dependencies must not silently become permission.

A role supplies a capability bundle; it is not sufficient authorization by itself.

Stakeholder permission matrix

Legend: `R` read; `W` create/update; `Q` request; `A` approve; `P` publish; – deny by default. Every allowed cell remains scope- and object-dependent.

Resource/action	Company operator	Finance reviewer	Institution admin	Security approver	Investor	Board director	Board observer	Alumni
Company execution records	R/W assigned	R financial scope	—	—	—	—	—	—
Financial reporting sources	Restricted R	R/W assigned	—	—	—	—	—	—
Reporting-package draft	W	R/A financial review	—	—	—	—	—	—
Publish disclosure package	P with separate grant	—	—	—	—	—	—	—
Published investor package	R if granted	R if granted	—	—	R audience-scoped	R if separately granted	— unless granted	—
Board package	Preparation access only	Assigned sections	—	—	—	R board-scoped	R explicitly granted	—
Governance decision	—	—	—	—	—	Q/record within authority	—	—

Resource/action	Company operator	Finance reviewer	Institution admin	Security approver	Investor	Board director	Board observer	Alumni
Institution configuration	—	—	R/W assigned	R assigned	—	—	—	—
High-risk admin change	—	—	Q	A independent	—	—	—	—
Educational records	—	—	— unless domain grant	—	—	—	—	Own permitted view only
Alumni personal portfolio	—	—	—	—	—	—	—	R/W own
Alumni directory	—	—	—	—	—	—	—	R opted-in fields
Mentoring relationship	—	—	—	—	—	—	—	Q/manage own
Audit records	Assigned business scope	Financial scope	Tenant scope	Security scope	Own access history	Governance scope	Own access history	Own history

Board directors obtain disclosures through approved packages, not an automatic read grant to finance or company source tables.

Company permission decomposition

Do not introduce a universal “company admin” with routine access to every domain.

Capability family	Typical owner	Restrictions
`company.product.*`	Product/engineering	Assigned product and release scope
`company.crm.*`	Revenue team	Assigned accounts; restricted contact exports
`company.implementation.*`	Implementation team	Customer scope; institutional data access separately authorized
`company.finance.*`	Finance	Financial confidentiality; independent reconciliation review
`company.people.*`	People operations	Personnel records isolated from general company search
`company.trust.*`	Trust/security	Restricted investigations and evidence
`reporting.prepare`	Reporting preparer	Cannot approve own work
`reporting.review`	Authorized reviewer	Section- and audience-specific
`reporting.publish`	Disclosure publisher	Approved version and recipient set only

Admin permission decomposition

Capability	Scope	Required gate
`admin.membership.manage`	Institution/unit	Cannot grant beyond delegated authority
`admin.policy.propose`	Institution/module	Versioned proposal

Capability	Scope	Required gate
`admin.policy.approve`	Institution/module	Independent approver for designated changes
`admin.integration.configure`	Named connection	Approved scopes and credential references
`admin.integration.replay`	Named run/object range	Impact preview and duplicate-effect protection
`admin.migration.execute`	Approved domain/run	Signed cutover decision and recovery readiness
`admin.export.request`	Dataset and purpose	Classification and recipient review
`admin.erase.execute`	Approved request	Retention/legal-hold checks
`admin.breakglass.activate`	Named incident/resources	Time limit, justification, review
`academic.record.write`	Academic domain	Separate institutional delegation—not implied by admin role

3. Data silos: one platform, bounded ownership

These are logical security partitions. Do not assume each requires a separate database; physical separation should follow deployment requirements and verified risk assessment.

Partition	Canonical contents	Permitted crossing mechanism
Personal-private	Notes, personal portfolio, private planning	Explicit sharing or approved derived evidence
Institutional-official	Enrollment, grades, official academic records	Domain-authorized services and approved reports
Institutional-operations	Integrations, configuration, support queues	Scoped operating workflows
Company-commercial	Accounts, contracts, implementation plans	Contract-governed customer collaboration
Company-financial/personnel	Financial sources, payroll, personnel	Restricted internal workflows; reviewed reporting
Investor-disclosure	Published updates and diligence materials	Versioned audience grants
Board-governance	Board packages, minutes, committee records	Board/committee grants and restricted preparation
Alumni-community	Opt-in profiles, chapters, mentoring	Visibility rules and relationship grants
Audit/evidence	Decisions, receipts, control evidence	Scoped audit views with sensitive-field protection

Boundary rules

1. Investor and board packages are publication objects, not unrestricted views into operational tables.
2. Student-private material does not become official or institution-visible merely because it links to a course.
3. Alumni identity does not preserve expired course, student-worker, or institutional privileges.
4. Company support access requires an explicit, bounded grant.
5. Search indexes, embeddings, thumbnails, caches, and exports inherit source classification.
6. Aggregates require an approved disclosure policy; removing names alone is not the publication gate.

7. Notifications carry minimal context and require authorization again when opened.

The existing institution template uses an illustrative cohort-suppression threshold. Treat that number as a template policy, not a universal institutional standard. [1]

4. Security model

Enforcement layers

Layer	Proposed control	Required proof
Identity	Verified accounts, invitation lifecycle, MFA for privileged actions	Joiner/mover/leaver and session tests
Request boundary	Resolve tenant from authenticated memberships	Forged-scope negative tests
Service	Check capability, object relationship, state, purpose	Direct API allow/deny tests
Database	Tenant/object policies; constrained function privileges	Cross-tenant and function-call tests
Storage	Authorized object access and bounded download mechanisms	Direct URL and revoked-access tests
Search/graph	Authorized candidates and authorized returned fields	Hidden-node and metadata-leakage tests
AI	Policy before retrieval, invocation, and tool use	Tenant AI-off and restricted-source tests
Worker	Bounded service identity; revalidate before effect	Revocation-during-job tests
Audit	Protected append-oriented records and scoped views	Tampering, retention, and investigation tests

The dated architecture document specifically reports that database function owners could bypass row-level security, and that tenant AI settings were not enforced at the call boundary. Verify and remediate those conditions before relying on either control. [3]

Privileged changes

For designated high-risk changes, require:

- Fresh authentication appropriate to the risk.
- Exact resource and impact preview.
- A reason and supporting evidence.
- Independent approval.
- Approval bound to the exact command payload and version.
- Revalidation immediately before execution.
- Idempotent effect handling.
- Audit and outbox records coordinated with the domain transaction.
- Read-back verification and reconciliation.
- A documented rollback or compensating-action path.

Changing the payload after approval invalidates that approval.

Revocation semantics

Revocation must affect:

- New API requests.
- Search and graph results.
- AI retrieval.
- Queued jobs before execution.
- File access.
- Active subscriptions and privileged sessions according to policy.

A downloaded copy cannot be remotely revoked. Download policy, contractual restrictions, and access logging remain separate controls.

5. Investor workflow specification

A. Invitation and access

```
Recipient identified
→ relationship verified
→ current-investor or prospective-investor audience selected
→ disclosure terms and expiry configured
→ invitation accepted
→ identity/session checks
→ approved packages become accessible
```

Prospective investors receive a separate diligence audience. They do not inherit historical investor updates.

B. Monthly reporting

Step	Owner	Output/gate
Open reporting period	Reporting lead	Period and metric-definition versions
Collect source snapshots	Domain owners	Traceable source versions
Reconcile financials	Finance	Reviewed actuals and forecast separation
Draft narrative	Management	Claims linked to evidence
Review disclosure	Authorized reviewers	Classification and audience sign-off
Freeze package	Reporting system	Immutable content manifest
Publish	Disclosure publisher	Exact version and recipient set
Notify	Notification service	Minimal authorized notice
Correct	Management + reviewers	New version with correction explanation

The existing board deck labels some figures as sample and distinguishes pilot services from contracted ARR. Preserve those distinctions in the reporting model; do not ingest deck figures as verified actuals.[4]

C. Questions and assistance

Investor question
→ linked to package/version
→ assigned management owner
→ reviewed answer
→ disclosed to the selected audience.

An introduction request may create an internal company task, but it must not give the investor access to the underlying customer account.

6. Board workflow specification

A. Meeting preparation

```
Meeting created
→ agenda proposed
→ committee and attendee scopes resolved
→ materials prepared
→ finance/legal/management reviews
→ package frozen
→ authorized distribution
→ preparation questions and private annotations
```

Personal annotations remain personal unless explicitly shared.

B. Decision record

```
Proposal version
→ authority and required process identified
→ eligible participants verified
→ conflicts/recusals recorded
→ decision captured through validated process
→ minutes/resolution reviewed
→ approved record retained
→ company follow-up actions assigned
```

Formal quorum, consent, voting, signature, and resolution workflows require validation against the governing documents and applicable process before activation. The prototype records draft decisions only.

C. Restricted sessions

- Separate session and material audience.
- Independent committee/observer grants.
- No unauthorized agenda snippets, notifications, search results, or AI summaries.
- Preparation access does not imply continuing director access.
- Approved governance records preserve the material versions considered.

D. Follow-up

A board action links to a Company task. Company operators receive the instruction and permitted context—not automatic access to the full board package.

7. Cross-workspace education graph schema

Schema strategy

Use canonical domain records for authority, with a graph projection for relationships and navigation. Do not turn a generic graph into a parallel source of truth.

All names below are proposed concepts, not verified existing tables.

Core entities

```
Person
Organization
Institution
OrganizationalUnit
Membership
Affiliation
Course
Program
Enrollment
Credential
EvidenceArtifact
Portfolio
Opportunity
MentoringRelationship
ImplementationPlan
PolicyVersion
WorkflowInstance
Approval
ReportingPackage
DisclosureGrant
GovernanceBody
Meeting
GovernanceDecision
AuditEvent
```

Proposed graph envelope

```
graph_node (
  id uuid primary key,
  node_type text not null,
  domain_owner text not null,
  canonical_record_id uuid not null,
  owning_org_id uuid,
  institution_id uuid,
  personal_owner_id uuid,
  classification text not null,
  policy_ref uuid not null,
  source_authority text not null,
```

```
  source_version text not null,
  valid_from timestamptz not null,
  valid_until timestamptz
);

graph_edge (
  id uuid primary key,
  source_node_id uuid not null,
  relation_type text not null,
  target_node_id uuid not null,
  authority_org_id uuid,
  classification text not null,
  policy_ref uuid not null,
  consent_grant_id uuid,
  evidence_ref uuid,
  valid_from timestamptz not null,
  valid_until timestamptz,
  revoked_at timestamptz
);
```

This envelope is not a deployable migration. Before implementation, reconcile canonical models, add endpoint constraints, foreign keys, indexes, allowed relation types, tenant-boundary validation, and tested authorization policies.

Relationship contracts

Relationship	Meaning	Permission consequence
Person → `MEMBER_OF` → Organization	Active organizational membership	Context eligibility only
Person → `AFFILIATED_WITH` → Institution	Student/alumni/staff affiliation	No blanket data permission
Person → `ENROLLED_IN` → Course	Authoritative enrollment	Course rights determined separately
Artifact → `EVIDENCES` → Competency	Evidence claim	Visibility stays with artifact policy
Person → `HOLDS` → Credential	Credential relationship	Claim and verification status remain distinct
Person → `MENTORS` → Person	Approved mentoring relationship	Only granted mentoring context
Plan → `IMPLEMENTS_FOR` → Institution	Delivery relationship	No academic-record access
Package → `DISCLOSES` → Snapshot	Reviewed reporting lineage	Internal lineage may remain restricted
Grant → `AUTHORIZES` → Package	Audience-specific access	No access to underlying source records
Decision → `GENERATES` → Task	Governed follow-up	Task receives bounded context
Approval → `AUTHORIZES` → Command	Exact approved execution	Payload change invalidates approval

Traversal policy

For every graph query:

1. Authorize the starting node.
2. Authorize each edge.
3. Authorize each destination node.

4. Restrict returned properties.
5. Apply approved traversal depth and query-cost limits.
6. Suppress unauthorized existence, counts, and adjacency metadata.
7. Recheck policy before downstream action.

Do not treat reachability as permission. A path from an investor to a reporting package to an institutional metric must not reveal the contributing students.

8. Alumni lifecycle and permissions

The existing role-onboarding template explicitly includes an Alumni journey, giving you a reusable onboarding entry point rather than requiring a separate identity product. [5]

Graduation transition

```
Verified affiliation change
→ explain service changes
→ preserve eligible personal work
→ revoke expired institutional capabilities
→ offer optional alumni affiliation
→ configure directory visibility
→ select communication preferences
→ optionally enable mentoring and career participation
```

Alumni-specific controls

- Distinguish verified affiliation from self-declared profile content.
- Make directory visibility field-specific.
- Separate institutional fundraising preferences from community participation.
- Let mentoring availability expire unless renewed.
- Give chapter leaders bounded event/community administration.
- Require a separate verified employer relationship for recruiting.
- Preserve reporting, blocking, appeal, and support paths.
- Keep credential verification distinct from unrestricted transcript access.

9. Interactive prototype: what it demonstrates

The generated HTML prototype includes:

- Eight simulated stakeholder roles.
- Company, Institution A, Institution B, and personal scopes.
- Immediate local revocation.
- Scope-mismatch negative tests.
- Simulated fresh-MFA checks.
- Independent report review before publication.

- Independent integration-change approval.
- Board-director versus observer differences.
- Alumni mentoring without academic-record sharing.
- A local allow/deny decision trail.

Suggested walkthrough

Test	Expected local result
Investor + Company scope	Published investor card allowed
Investor + Institution A	Institutional object denied
Institution admin + Institution B	Institution A object denied
Company operator drafts, Finance reviewer reviews	Report reaches reviewed state
Company operator publishes reviewed report	Local published state
Institution admin requests, Security approver approves	Approved; execution explicitly unimplemented
Board observer records decision	Denied
Board director records decision	Draft decision only
Revoke selected role	Subsequent object/action checks denied
Clear simulated MFA, attempt controlled action	Denied

These are demonstration scenarios. I verified that the generated artifacts exist and are non-empty; I have not run automated browser or production-security tests.

The prototype's JSON catalog is intentionally narrower than the proposed production matrix. For example, its Company operator combines drafting and local publication for the demonstration; production publication should use a separately assigned grant.

10. Implementation backlog and activation gates

Priority	Deliverable	Accountable owner	Acceptance evidence
P0	Reconcile roles, scopes, canonical records, and existing policies	Platform + security	Inventory and duplicate/gap register
P0	Server-side context and policy enforcement	Platform + security	API, database, function, storage negative tests
P0	AI and search policy enforcement	AI/platform leads	Restricted-source, revocation, tenant-AI-off tests
P0	Approval-bound commands	Domain engineering	Payload-change, self-approval, replay tests
P1	Reporting snapshots and audience grants	Finance + reporting	Reconciliation and disclosure lineage
P1	Board preparation and governance records	Corporate secretary + engineering	Restricted-session and authority tests
P1	Alumni affiliation transition	Identity + alumni lead	Expired-role removal and personal-data preservation

Priority	Deliverable	Accountable owner	Acceptance evidence
P1	Graph projection and traversal	Data/platform	Edge, node, property, count-leakage tests
P1	Accessibility and recovery	Design + operations	Keyboard/screen-reader completion and restore evidence
P2	Production UI integration	Product/design + engineering	Complete workflow and release evidence

Production release gate

No workspace becomes production-enabled until it has:

- Verified identity and lifecycle behavior.
- Tenant, object, field, and relationship authorization.
- Tested revocation.
- Controlled approvals and durable receipts.
- Search, storage, worker, graph, and AI enforcement.
- Approved retention and disclosure rules.
- Accessible workflows and support paths.
- Monitoring, recovery, and reconciliation evidence.
- Required institutional or corporate authority.
- A reviewed status ledger separating designed, implemented, tested, deployed, authorized, and production-enabled states.

The existing templates can accelerate the interface work. The dated architecture findings make the security spine—not additional dashboard screens—the first production dependency.[2] [1] [3]

⁂

1. The Main Semester design system (2) copy/templates/institution-os/InstitutionOs.dc.html
2. The Main Semester design system (2) copy/templates/console-screen/ConsoleScreen.dc.html
3. The Main Semester design system (2) copy/uploads/Semester build Architecture.pdf
4. The Main Semester design system (2) copy/exports/Semester Board Update.pptx
5. The Main Semester design system (2) copy/templates/role-onboarding/RoleOnboarding.dc.html